

Name: Neel Pankaj Soni

Student ID: 1259189 | **Course:** CIS*6550 – Privacy, Compliance and Human-Cyber | **Assignment:** #2

Introduction

Artificial Intelligence (AI) is increasingly deployed in financial services to enhance credit risk assessment and personalize loan recommendations. An **AI Credit Risk & Recommendation System** in the consumer lending context leverages supervised learning on historical credit data to predict default probabilities and employs recommendation algorithms to tailor loan offers and terms to individual borrowers. These capabilities aim to improve decision-making efficiency, reduce operational costs, and expand financial inclusion.

However, such systems introduce significant challenges related to privacy, fairness, explainability, and regulatory compliance. Sensitive financial and demographic data used for model training can expose individuals to privacy risks if not properly safeguarded. Algorithmic bias may lead to discriminatory lending practices, undermining fairness and trust. Furthermore, opaque models complicate explainability, which is essential for consumer transparency and regulatory audits. These concerns are amplified by the EU AI Act's classification of credit scoring as a **high-risk AI application**, requiring stringent governance and oversight (Regulation (EU) 2024/1689).

This assignment aims to:

1. Identify data types and map actors/roles in the AI lifecycle.
2. Conduct AI risk analysis using the NIST AI Risk Management Framework (AI RMF 1.0).
3. Perform privacy threat modeling aligned with the NIST Privacy Framework and NISTIR 8062 principles.
4. Develop an audit and compliance framework incorporating NIST SP 800-53 Rev. 5 and OSFI guidelines.

System Overview of AI Credit Risk & Recommendation System

The AI Credit Risk & Recommendation System in consumer lending integrates predictive analytics and recommendation engines to optimize credit decisions. Inputs include structured financial data (income, credit history, payment behavior), demographic attributes, and alternative data sources. Core models typically employ gradient boosting machines (GBMs) or transformer-based architectures for credit risk scoring, while recommendation logic uses collaborative filtering or reinforcement learning to personalize loan terms. Outputs consist of a risk score (e.g., probability of default) and recommended credit products or terms. Decision boundaries are defined by institutional risk appetite and regulatory constraints, with human-in-the-loop checkpoints for high-risk or borderline cases to ensure accountability.

The operating context involves data pipelines for ingestion, preprocessing, and feature engineering, followed by a model lifecycle encompassing training, validation, deployment, and continuous monitoring. Feedback loops incorporate repayment performance and customer complaints to recalibrate

models and mitigate drift. Governance aligns with NIST SP 800-37 RMF lifecycle principles, embedding security and privacy controls throughout system development.

Trustworthiness attributes per NIST AI RMF 1.0 include:

- Validity and Reliability through rigorous testing and bias audits.
- Safety and Resilience against adversarial inputs and systemic failures.
- Accountability and Transparency via documented decision logic and audit trails.
- Privacy-Enhanced Design leveraging minimization and differential privacy.
- Explainability through interpretable models or post-hoc techniques (e.g., SHAP).

Data Types and Sources for AI Credit Risk & Recommendation System

The system aggregates data from internal sources such as core banking platforms (account balances, repayment history), CRM systems (customer profiles), and transaction logs. External sources include credit bureaus for credit scores, KYC vendors for identity verification, sanctions and PEP screening lists, and fraud detection consortia. Additionally, derived features, such as behavioral scores and embeddings, are generated during feature engineering to enhance predictive accuracy.

Key data types processed include:

- PII: Name, address, date of birth, government-issued identifiers.
- Financial: Income, credit limits, outstanding balances, repayment history.
- Behavioral: Spending patterns, delinquency trajectories.
- Device/Metadata: IP addresses, device IDs, geolocation.
- Model Artifacts: Features, parameters, logs.

The data lifecycle aligns with NIST Privacy Framework principles: collection with consent, minimization, purpose limitation, retention/deletion policies, and strict access controls. Data quality and labeling support model validity under NIST AI RMF, while lineage and provenance ensure accountability. Privacy engineering concepts from NISTIR 8062, identifiability, predictability, and manageability, guide mitigation strategies. Techniques such as aggregation and de-identification reduce identifiability, though residual re-identification risks persist. Sensitive attributes (e.g., race, gender) require governance to prevent bias and discrimination, consistent with fairness and compliance obligations under PIPEDA.

Actor Identification and Analysis

The AI Credit Risk & Recommendation System operates within a complex ecosystem involving multiple actors with distinct roles and responsibilities. Data subjects (customers) provide personal and financial data, exercising rights under privacy regulations. The data controller, typically the financial institution, oversees governance, accountability, and compliance, including conducting Data Protection Impact Assessments (DPIAs). Data processors, such as cloud service providers, credit bureaus, and

MLOps vendors, handle data storage, model deployment, and third-party integrations under strict Data Processing Agreements (DPAs) and Service Level Agreements (SLAs) (NIST, 2023).

Model developers and data engineers are responsible for algorithm design, feature engineering, and ensuring fairness and explainability. Risk, compliance, and legal teams manage regulatory adherence, while internal audit and independent auditors validate controls and monitor segregation of duties. Regulators and supervisors (e.g., OSFI in Canada) enforce compliance and oversee systemic risk. Customer support addresses complaints and facilitates human-in-the-loop decisioning for adverse actions. Third-party model providers supply pre-trained algorithms, requiring contractual safeguards to mitigate conflicts of interest.

Interactions follow a RACI structure: financial institutions are Accountable, model developers and processors are Responsible, auditors and regulators are Consulted, and customers are Informed. Interfaces include APIs for data exchange and contractual agreements for governance. Segregation of duties between development, risk oversight, and audit functions prevents concentration of power and ensures transparency (GAO, 2025; BIS, 2024).

AI System Risk Analysis

The AI Credit Risk & Recommendation System presents multiple risks across its lifecycle. Key risks include data bias and representativeness gaps, which can lead to discriminatory outcomes; performance drift, where models degrade over time; privacy leakage through re-identification; security vulnerabilities such as adversarial attacks; and limited transparency, which affects explainability and accountability. Human factors, including automation bias and over-reliance on AI outputs, further amplify systemic risk (NIST, 2023; BIS, 2024).

Using the NIST AI RMF, risk management follows four core functions:

- Govern: Establish accountability, segregation of duties, and oversight committees.
- Map: Identify socio-technical risks, document data lineage, and classify the system as “high-risk” under the EU AI Act, requiring logs, human oversight, and quality controls.
- Measure: Apply fairness metrics, robustness testing, and privacy impact assessments.
- Manage: Implement continuous monitoring, retraining protocols, and incident response plans (GAO, 2025).

Qualitative Risk Matrix:

Risk Matrix	Likelihood	Impact
Data bias	High	High
Privacy Leakage	Medium	High
Performance Drift	High	Medium
Adversarial ML	Medium	High
Transparency Limits	High	Medium
Automation Bias	Medium	Medium

Credit scoring's high-risk classification under the EU AI Act mandates strict documentation, explainability, and human-in-the-loop decisioning to mitigate systemic harm.

Privacy Risk Analysis

The AI Credit Risk & Recommendation System introduces privacy threats across data collection, processing, and inference stages. Key threats include re-identification of pseudonymized data, inference of sensitive attributes (e.g., ethnicity from spending patterns), unauthorized secondary use, function creep, and linkage attacks combining internal and external datasets. Advanced risks such as membership inference and model inversion can expose training data, while insider misuse and third-party misuse remain persistent concerns. Overcollection and retention beyond necessity amplify compliance risks under privacy laws (NIST, 2023; BIS, 2024).

Threats map to PII (e.g., SIN vulnerable to linkage attacks), financial data (susceptible to inference and misuse), and behavioral data (prone to profiling and function creep). Actors implicated include data controllers, processors, and third-party vendors. System outputs, credit scores and recommendations can indirectly reveal sensitive traits.

Mitigations align with the NIST Privacy Framework and AI RMF: enforce data minimization, purpose specification, and deploy Privacy-Enhancing Technologies (PETs) such as differential privacy, secure enclaves, and federated learning. Role-based access, logging, and red-teaming address insider and external threats. Transparency measures, user notices, consent management, and human-in-the-loop checkpoints, reduce automation bias. Residual risk persists due to trade-offs between model utility and privacy, requiring continuous monitoring and governance (GAO, 2025).

Research Methodology

A standards-first strategy guided the research, prioritizing the NIST AI RMF 1.0, NIST Privacy Framework, NIST SP 800-53 Rev. 5, and SP 800-37 for lifecycle governance, supplemented by NISTIR 8062 for privacy engineering concepts. Regulatory triangulation drew on the EU AI Act (credit scoring as high-risk), OSFI E-23 for Canadian model risk, and ISO/IEC 27001 for information security alignment (NIST, 2023; NIST, 2020a, 2020b; NIST, 2017; European Commission, 2024; OSFI, 2025; ISO, 2022). Sources were selected for credibility, jurisdictional relevance, and applicability to privacy/compliance. Limitations included scope and time constraints and gaps in vendor documentation; these were mitigated through conservative assumptions, citation of authoritative texts, and explicit documentation of uncertainties.

Framework Development

The audit framework maps Govern–Map–Measure–Manage to system components (governance, data lifecycle, model development/validation, operations). Privacy-by-design controls derive from the Privacy Framework (identify/control/communicate/protect) and are implemented via SP 800-53 control families (e.g., PM, RA, AU, AC, CM, IR, SR) with lifecycle rigor per SP 800-37 (NIST, 2020a, 2020b;

NIST, 2023). Rationale: clear accountability, data minimization and user rights, and continuous monitoring for drift, bias, and security.

Key Audit Findings

The system qualifies as high-risk under the EU AI Act. Observed risks: bias/representativeness gaps, explainability limits, privacy leakage, and adversarial ML exposure; gaps: incomplete technical documentation, limited drift/bias monitoring, and insufficient end-user transparency. Strengths: encryption, role-based access, and a completed DPIA (European Commission, 2024; NIST, 2020b). Residual risks remain moderate due to model opacity; recommendations include PETs (e.g., differential privacy), enhanced monitoring/KRIs, and periodic external assurance aligned to OSFI E-23 (NIST, 2017; OSFI, 2025).

Comparison of ChatGPT and DeepSeek AI Tools

Method: Both tools were prompted using structured academic instructions emphasizing NIST alignment, and compliance context. Iterative refinement and guardrails (tone, citation rules, word limits) ensured consistency.

Findings: ChatGPT demonstrated superior controllability, adherence to formatting, and ability to integrate NIST frameworks into structured outputs. It consistently produced verifiable citations and well-organized audit artifacts. However, occasional hallucinations required cross-checking. DeepSeek excelled in generating concise summaries and technical depth but showed weaker citation transparency and higher hallucination risk for regulatory details. Both tools handled factual accuracy well for standards but struggled with vendor-specific documentation.

Strengths vs. Limitations: ChatGPT is preferable for compliance-oriented writing and framework design due to its structured reasoning and citation quality. DeepSeek is useful for rapid synthesis and technical comparisons but needs stricter prompt engineering for academic rigor.

Recommendation: Use ChatGPT for formal deliverables and DeepSeek for exploratory drafts. Prompt tips: specify “NIST alignment,” and “avoid fabricated sources” to reduce hallucination risk.

References

- Bank for International Settlements. (2024). Regulating AI in the financial sector: Recent developments and main challenges. <https://www.bis.org/fsi/publ/insights63.pdf>
- European Commission. (2024). Regulation (EU) 2024/1689 – Artificial Intelligence Act. <https://ec.europa.eu/>
- European Commission. (2024). Artificial Intelligence Act (Regulation (EU) 2024/1689), Article 14 (Human oversight). <https://artificialintelligenceact.eu/article/14/>
- International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information Security Management Systems. <https://www.iso.org/standard/27001>
- KPMG. (2024). Setting the ground rules: The EU AI Act. <https://kpmg.com/xx/en/our-insights/ecb-office/setting-the-ground-rules-the-eu-ai-act.html>
- National Institute of Standards and Technology. (2017). An introduction to privacy engineering and risk management in federal systems (NISTIR 8062). <https://doi.org/10.6028/NIST.IR.8062>
- National Institute of Standards and Technology. (2018). Risk management framework for information systems and organizations: A system life cycle approach for security and privacy (SP 800-37 Rev. 2). <https://doi.org/10.6028/NIST.SP.800-37r2>
- National Institute of Standards and Technology. (2020a). NIST Privacy Framework: A tool for improving privacy through enterprise risk management (Version 1.0). <https://www.nist.gov/privacy-framework>
- National Institute of Standards and Technology. (2020b). Security and privacy controls for information systems and organizations (SP 800-53 Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>
- National Institute of Standards and Technology. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). <https://doi.org/10.6028/NIST.AI.100-1>
- Office of the Superintendent of Financial Institutions. (2024). Guideline E-23: Model risk management. Government of Canada. <https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/guideline-e-23-model-risk-management-2027>
- Office of the Superintendent of Financial Institutions. (2025). Guideline E-23 – Model risk management (effective May 1, 2027). <https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/guideline-e-23-model-risk-management-2027>
- U.S. Government Accountability Office. (2025). Artificial intelligence: Use and oversight in financial services (GAO-25-107197). <https://www.gao.gov/assets/gao-25-107197.pdf>
- OpenAI. (2025). *ChatGPT* (November 14, 2025) [Large language model]. <https://openai.com>
- DeepSeek AI. (2025). *DeepSeek* (November 14, 2025) [Large language model]. <https://deepseek.com>

Appendix

Audit Framework for Ongoing Assurance (NIST-Aligned)

Structure & Alignment. The framework integrates the NIST AI Risk Management Framework functions—Govern, Map, Measure, Manage—with the NIST Privacy Framework (Identify-P, Govern-P, Control-P, Communicate-P, Protect-P) and maps activities to NIST SP 800-53 Rev. 5 control families. Lifecycle governance, authorization decisions, and continuous monitoring follow NIST SP 800-37 Rev. 2 (NIST, 2023; NIST, 2020a, 2020b).

Core Components:

- Governance. Define roles (AI/model risk committee, system owner, CPO, CISO), segregation of duties, a model inventory, and a policy baseline for model risk, privacy, and security (NIST, 2023; NIST, 2020b).
- Data lifecycle controls. Data mapping, lawful basis, minimization/retention, consent/rights management, lineage, and protection in transit/at rest (NIST, 2020c).
- Model development & validation. Document datasets and assumptions (model/dataset cards), ensure reproducibility, and test performance, robustness, fairness, and explainability; include adversarial/red-team testing (NIST, 2023; NIST, 2020b).
- Operational controls. Change management; third-party/vendor oversight (DPAs/SLAs, assurance reports); logging/traceability; incident & complaint management; user rights (access, correction, deletion); KPIs/KRIs and continuous monitoring for drift/bias (NIST, 2023; NIST, 2020b).

Procedures:

- Pre-deployment review. Design dossier (purpose, actors, data), DPIA/PIA, security/privacy control selection, and go/no-go with risk acceptance (NIST, 2020a, 2020c).
- Post-deployment monitoring. Track drift (e.g., PSI/KS), fairness deltas (e.g., adverse-impact ratio), robustness regressions, privacy budgets (if PETs used), and audit-quality logs (NIST, 2023).
- Audit trails & evidence. Immutable logs of data access, training runs, model versions, overrides, and user notices; sample decisions for periodic testing; maintain evidence bundles for internal audit and regulators (NIST, 2020b).
- Issue remediation & escalation. Threshold-based triggers (e.g., fairness ratio <0.80; critical incident MTTR > 72h) → hot-fix, rollback, POA&M tracking, committee review; reporting cadence quarterly to management and on request to supervisors (NIST, 2020a, 2020b).

Concise Control Checklist (mapped to NIST artifacts):

AI RMF	Privacy Framework	Objective (examples)	Evidence	Owner/Frequency	SP 800-53 Rev. 5
--------	-------------------	----------------------	----------	-----------------	------------------

Govern	Govern-P	Charter, roles, SoD, model inventory	Charter, minutes, inventory	CRO/CPO; annual	PM-1, PM-9, RA-1
Map	Identify-P/Control-P	Data lineage, lawful basis, DPIA/PIA	RoPA/DPIA, data map	Privacy; quarterly	AR-2, DM-1/DM-2, IP-1
Measure	Protect-P	Access control & traceability	IAM configs, access reviews	IAM; monthly	AC-2/AC-6, AU-6/AU-12
Measure	Control-P	Reproducible training/validation; fairness/robustness	Model/dataset cards; test reports	MLOps; per release	SA-11, RA-5, SI-4
Manage	Protect-P	Adversarial testing & red-team	Red-team plan/results	Sec-ML; quarterly	SI-4, SR-3
Manage	Communicate-P	Notices, explanations, HIL checkpoints	Templates; override logs	Compliance; semiannual	AR-8, AU-6
Manage	Govern-P	Vendor oversight (DPA/SLA, assurance)	DPA/SLA; SOC/ISO reports	TPRM; annual	SR-3/SR-5, CA-7
Manage	Control-P	Change & drift/bias monitoring	Change tickets; drift alarms	MLOps; continuous	CM-3, SI-2, AU-12

EU AI Act accommodation. Credit scoring is high-risk, requiring technical documentation, quality management, event logging, and effective human oversight (e.g., reason codes and HIL review for adverse actions). These obligations are embedded within Govern/Map (documentation), Measure (testing/metrics), and Manage (oversight, logging, post-market monitoring) (European Commission, 2024).

Jurisdictional note (Canada). For FRFIs, align evidence and model lifecycle governance with OSFI Guideline E-23 on model risk, alongside 800-53 controls and SP 800-37 monitoring (OSFI, 2025; NIST, 2020a).

Prompts Used for Both AI Tools

Prompt For Context:

ROLE: You are an experienced cybersecurity/privacy professional with experience of 10 years in field.

TOPIC: AI Credit Risk & Recommendation System in Financial Services (consumer lending context).

FRAMEWORKS/FOCUS:

- Primary: NIST AI Risk Management Framework (AI RMF 1.0), NIST Privacy Framework, NIST SP 800-53 Rev. 5, NIST SP 800-37, NIST IR 8062.
- Secondary (for comparison or legal framing when relevant): EU AI Act (Regulation (EU) 2024/1689, high-risk classification for credit scoring), ISO/IEC 27001:2022, ISO/IEC 27002:2022, OSFI Guidelines (e.g., E-23 Model Risk Management), PIPEDA (Canada).
- Use NIST as the organizing backbone throughout.

STYLE & FORMAT:

- Tone: Formal, objective.
- Include a short “References” subsection at the end of every section. Use only verifiable, authoritative sources (standards, regulations, government/agency publications, reputable journals). Do not fabricate citations.
- Maintain consistent terminology across sections (e.g., “AI Credit Risk & Recommendation System,” “data subjects,” “data controllers/processors,” “risk appetite,” “model risk,” “impact/likelihood,” “governance,” “data lifecycle,” “human-in-the-loop”).
- Keep cross-section consistency (assumptions, actors, data types, risks, controls).
- If assumptions are necessary, state them explicitly and align them with prior sections.

Prompts:

“Explain the core functionality of an AI Credit Risk & Recommendation System in financial services. What are its main objectives, how does it use machine learning models, and why is it considered high-risk under global AI regulations? Identify trustworthiness attributes (e.g., fairness, explainability, privacy) that should be prioritized.”

“List all possible data sources and data types used by an AI credit risk system. Categorize them into personal identifiable information (PII), financial, behavioral, and technical metadata. For each category, explain why it is privacy-sensitive and how it flows through the AI lifecycle (collection, processing, storage, deletion).”

“Identify all actors involved in the AI credit risk ecosystem (e.g., data subjects, data controllers, processors, regulators, auditors, developers). For each actor, describe their responsibilities, decision-making authority, and interaction points with the AI system. Highlight any accountability or governance challenges.”

“Break down the NIST AI Risk Management Framework functions (Govern, Map, Measure, Manage) and explain how each applies to an AI credit risk system. What activities or controls should be implemented under each function to ensure trustworthy AI and privacy compliance?”

“Identify the top risks associated with an AI credit risk system (e.g., bias, explainability gaps, privacy leakage, adversarial attacks). Classify these risks by likelihood and impact using a qualitative risk matrix. Explain why this system qualifies as high-risk under the EU AI Act and what additional obligations that triggers.”

“Construct a privacy threat model for the AI credit risk system. What are the main privacy threats (e.g., re-identification, inference attacks, unauthorized secondary use)? Map these threats to specific data types and actors. Suggest privacy-enhancing technologies (PETs) or controls to mitigate these threats.”

“Outline the key components of an audit framework for an AI credit risk system aligned with NIST AI RMF and NIST Privacy Framework. What governance structures, lifecycle controls, monitoring mechanisms, and user rights management processes should be included? How will compliance audits and continuous monitoring be performed?”

“Describe the research approach for building this assignment. What sources (standards, regulations, academic literature) should be prioritized? How will you map NIST principles to the AI system’s lifecycle? What methodology will you use to design the audit framework and validate its completeness?”